

DAI HOC QUOC GIA THANH PHO HO CHI MINH
TRUONG DAI HOC KHOA HOC TU NHIE
KHOA TOAN — TIN HOC

BAO CAO THUC HANH

Lab05: PHP Database CRUD, PDO Repository,
Pagination, Unique & Index

Ung dung: *ClinicDesk* — *Mini Clinic Appointment DB App*

Giang vien huong dan: TS. Tran Anh Tuan
Mon hoc: Lap trinh Web
Sinh vien thuc hien: Le Pham Hong Hien
MSSV: 22110059

TP. Ho Chi Minh, Thang 6/2026

Mục lục

1	Cau 1: Xây dựng ứng dụng ClinicDesk	2
1.1	Gioi thieu ung dung	2
1.2	Kiem tra moi truong (T01)	3
1.3	Cau truc du an (T02)	3
1.4	Cau hinh PSR-4 Autoload (khong dung composer toan cuc)	4
1.5	Thiet ke Database — Schema (T03)	4
1.6	Seed du lieu (T04)	6
1.7	Ket noi PDO — Database class (T05)	7
1.8	Health check (T06)	8
1.9	Repository + Prepared Statements (T07)	8
1.10	ORDER BY an toan — Whitelist (T08)	9
1.11	Phan trang an toan — Paginator (T16)	10
1.12	Xu ly trung Unique key (T11, T15)	11
1.13	Luong CRUD + PRG Pattern (T10, T12, T13)	12
1.14	Module Lich hen — search, filter status, sort (T14, T15)	15
1.15	Xu ly loi an toan — 404 / 405 / 500 (T17, T18)	15
1.16	Bang Routes day du	16
2	Checklist task T01–T20 va ket qua test	17
2.1	Checklist task bat buoc T01–T20	17
2.2	Bang ket qua Test (TC01–TC15)	18
2.3	EXPLAIN — Kiem tra index (T19)	19
3	Cau 2: Problem Solving	21
3.1	Cau 2.1 — Database design	21
3.2	Cau 2.2 — PDO connection	21
3.3	Cau 2.3 — Prepared statements	21
3.4	Cau 2.4 — Repository pattern	22
3.5	Cau 2.5 — CRUD sach	22
3.6	Cau 2.6 — Unique constraint va duplicate key	22
3.7	Cau 2.7 — PRG Pattern	22
3.8	Cau 2.8 — Search, pagination va sort an toan	22
3.9	Cau 2.9 — Index va EXPLAIN	23
3.10	Cau 2.10 — Safe error message	23
3.11	Cau 2.11 — Delete bang POST	23
3.12	Cau 2.12 — Huong phat trien tiep theo	24
4	Ket luan	25
5	Bang kiem tra yeu cau (coverage)	25

1 Cau 1: Xay dung ung dung ClinicDesk

1.1 Gioi thieu ung dung

Em chon huong **Mini Clinic Appointment DB App** — dat ten la **ClinicDesk**. ClinicDesk la mot ung dung quan ly phong kham nho, gom **hai module nhiep vu**:

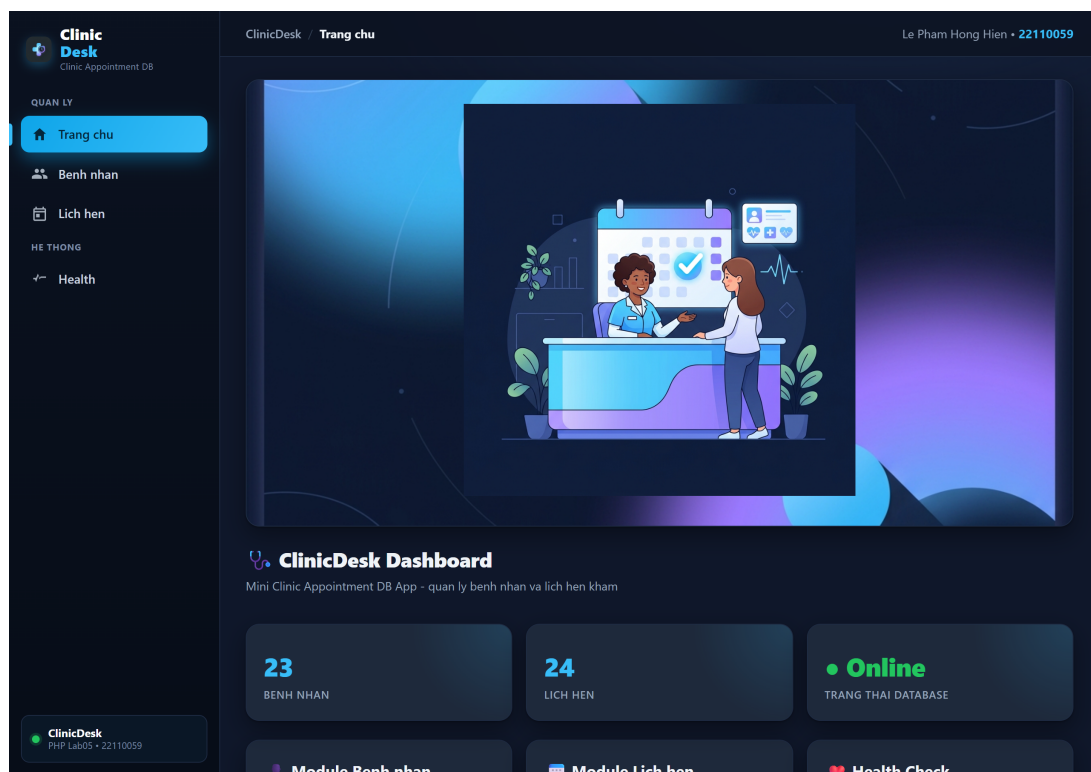
- **Module A — Benh nhan (/patients)**: quan ly ho so benh nhan (ho ten, email *unique*, so dien thoai, gioi tinh, dia chi).
- **Module B — Lich hen (/appointments)**: quan ly lich hen kham (ma lich hen *unique*, ten/email benh nhan, chuyen khoa, ngay gio, trang thai, ghi chu).

Ca hai module deu co **CRUD day du** (List, Create, Edit, Update, Delete), **tim kiem**, **phan trang**, **sap xep an toan** (whitelist), **unique constraint** chong trung va **xu ly loi an toan**. Database ten la `clinic_appointment_db`.

Giao dien duoc thiet ke lai theo phong cach **admin hien dai**: thanh dieu huong (sidebar) co dinh ben trai voi icon SVG va trang thai active mau xanh sky, thanh top-bar kem breadcrumb, the (card) bo goc co do bong nhieu lop, bang co header dinh (sticky), badge trang thai, va co the thu gon thanh ngan keo (drawer) tren man hinh nho — van giu nhan dien *toi* (dark navy + sky-blue + violet).

Kien truc tong the tuan thu dung tinh than Lab05:

```
Browser -> public/index.php (Front Controller) -> Router ->
Controller
    -> Repository -> PDO -> MySQL -> View / Redirect ->
    Browser
```



Hình 1: Trang chu (GET /) — dashboard hien so benh nhan, so lich hen va trang thai Database.

1.2 Kiem tra moi truong (T01)

- **PHP:** 8.2.12 (XAMPP) — C:/xampp/php/php.exe.
- **CSDL:** MariaDB 10.4.32 (XAMPP), user root, khong mat khau. Kiem tra:

```
C:/xampp/mysql/bin/mysql.exe -u root -e "SELECT VERSION();"
# -> 10.4.32-MariaDB
C:/xampp/php/php.exe -v
# -> PHP 8.2.12
```

- **Git + GitHub:** <https://github.com/lphhien112-gif/PHP->
- **IDE:** Visual Studio Code. **Test:** curl + trình duyệt.
- **Autoload:** PSR-4 qua vendor/ (copy tu Lab03 va sua mapping ClinicDesk\ => app/), chay khong can composer toan cuc.

*[Anh chup man hinh] Terminal: php -v (8.2.12) va SELECT VERSION()
(10.4.32-MariaDB).*

1.3 Cau truc du an (T02)

```
ClinicDesk/
|-- composer.json          # PSR-4: "ClinicDesk\\" => "app/"
|-- public/
|   |-- index.php          # Front Controller (entry point duy nhat)
|   |-- .htaccess          # rewrite tat ca -> index.php
|   '-- assets/css/style.css
|-- config/
|   |-- app.php            # ten app, debug, per_page, log path
|   '-- database.php       # thong tin ket noi (tach khoi controller/view)
|-- app/
|   |-- Core/
|   |   |-- Database.php   # PDO Singleton
|   |   |-- Router.php     # METHOD+PATH -> Controller@Action, 404/405/500
|   |   |-- Response.php   # html/json/redirect/404/405/500
|   |   |-- View.php       # render view + escape
|   |   |-- Paginator.php  # clamp page, tinh offset
|   |   |-- Flash.php      # flash message (PRG)
|   |   '-- Logger.php     # ghi log loi DB
|   |-- Controllers/
|   |   |-- HomeController.php
|   |   |-- HealthController.php
|   |   |-- PatientController.php
|   |   '-- AppointmentController.php
```

```
| |-- Repositories/
| | |-- PatientRepository.php      # toan bo SQL module A
| | '-- AppointmentRepository.php  # toan bo SQL module B
| '-- Views/
|     |-- layout.php  home.php
|     |-- patients/   (index, create, edit, _form)
|     |-- appointments/ (index, create, edit, _form)
|     '-- errors/     (404, 405, 500)
|-- database/
| |-- schema.sql      # 3 bang: users, patients, appointments
| |-- seed.sql        # 22 patients, 24 appointments, 1 user
| '-- seed_data.php   # (bonus) sinh 100-300 ban ghi
|-- storage/logs/app.log # log loi DB
'-- vendor/           # autoload PSR-4 (da map ClinicDesk\ -> app/)
```

[Anh chup man hinh] VS Code Explorer hien cay thu muc ClinicDesk dung cau truc tren.

1.4 Cau hinh PSR-4 Autoload (khong dung composer toan cuc)

Vi may khong co `composer` toan cuc, em copy thu muc `vendor/` tu Lab03 (BookNest) roi sua ba file mapping de tro namespace `ClinicDesk\` ve thu muc `app/`:

Listing 1: `vendor/composer/autoload_psr4.php` (da sua)

```
return array(
    'ClinicDesk\\' => array($baseDir . '/app'),
);
```

Listing 2: `composer.json`

```
{
    "name": "clinicdesk/mini-clinic-appointment-db-app",
    "autoload": { "psr-4": { "ClinicDesk\\": "app/" } },
    "require": { "php": ">=8.1", "ext-pdo": "*" }
}
```

Nho do PHP tu tim `ClinicDesk\\Core\\Database` tai `app/Core/Database.php`, `ClinicDesk\\Repository` tai `app/Repositories/PatientRepository.php`... Ung dung chay duoc bang `php -S 127.0.0.1:8105 -t public`.

1.5 Thiet ke Database — Schema (T03)

Database `clinic_appointment_db` co **ba bang**: `users` (tai khoan quan tri, de mo rong auth sau nay) va hai bang nghiep vu `patients`, `appointments`. Toan bo dung `ENGINE=InnoDB` va charset `utf8mb4` de luu tieng Viet co dau.

Listing 3: database/schema.sql — bang users

```

CREATE TABLE users (
  id          INT UNSIGNED NOT NULL AUTO_INCREMENT,
  username    VARCHAR(50)  NOT NULL,
  full_name   VARCHAR(120) NOT NULL,
  role        VARCHAR(20)  NOT NULL DEFAULT 'staff',
  password_hash VARCHAR(255) NOT NULL,
  created_at  TIMESTAMP    NOT NULL DEFAULT
    CURRENT_TIMESTAMP,
  updated_at  TIMESTAMP    NOT NULL DEFAULT
    CURRENT_TIMESTAMP
    ON UPDATE CURRENT_TIMESTAMP,
  PRIMARY KEY (id),
  UNIQUE KEY uq_users_username (username)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_uni
  code_ci;

```

Listing 4: database/schema.sql — bang patients

```

CREATE TABLE patients (
  id          INT UNSIGNED NOT NULL AUTO_INCREMENT,
  name        VARCHAR(120) NOT NULL,
  email       VARCHAR(150) NOT NULL,
  phone       VARCHAR(20)  NOT NULL,
  gender      ENUM('male','female','other') NOT NULL DEFAULT '
    other',
  address     VARCHAR(255) NULL,
  created_at  TIMESTAMP    NOT NULL DEFAULT CURRENT_TIMESTAMP,
  updated_at  TIMESTAMP    NOT NULL DEFAULT CURRENT_TIMESTAMP
    ON UPDATE CURRENT_TIMESTAMP,
  PRIMARY KEY (id),
  UNIQUE KEY uq_patients_email (email),           -- chan trung
    email
  KEY idx_patients_phone (phone),                 -- search theo
    SDT
  KEY idx_patients_created_at (created_at)        -- sort moi
    nhát
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_uni
  code_ci;

```

Listing 5: database/schema.sql — bang appointments

```

CREATE TABLE appointments (
  id          INT UNSIGNED NOT NULL AUTO_INCREMENT,
  appointment_code VARCHAR(20) NOT NULL,
  patient_name VARCHAR(120) NOT NULL,
  patient_email VARCHAR(150) NOT NULL,
  department   VARCHAR(80)  NOT NULL,
  appointment_date DATETIME NOT NULL,
  status       ENUM('pending','confirmed','completed','
    cancelled')

```

```

        NOT NULL DEFAULT 'pending',
note          VARCHAR(255) NULL,
created_at    TIMESTAMP NOT NULL DEFAULT
CURRENT_TIMESTAMP,
updated_at    TIMESTAMP NOT NULL DEFAULT
CURRENT_TIMESTAMP
                                ON UPDATE CURRENT_TIMESTAMP,
PRIMARY KEY (id),
UNIQUE KEY uq_appointments_code (appointment_code),
-- chan trung ma
KEY idx_appointments_status_created (status, created_at),
-- filter+sort
KEY idx_appointments_date (appointment_date),
KEY idx_appointments_code (appointment_code)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_unico
d_ci;

```

Mo ta PRIMARY KEY / UNIQUE / INDEX:

Bang	Loai khoa	Cot / Y nghĩa
users	PRIMARY KEY	id
users	UNIQUE	username (khong trung tai khoan)
patients	PRIMARY KEY	id
patients	UNIQUE	email (chan trung email benh nhan)
patients	INDEX	phone (search SDT)
patients	INDEX	created_at (sort moi nhat)
appointments	PRIMARY KEY	id
appointments	UNIQUE	appointment_code (chan trung ma lich hen)
appointments	INDEX	(status, created_at) — filter roi sort
appointments	INDEX	appointment_date
appointments	INDEX	appointment_code

[Anh chup man hinh] phpMyAdmin/Workbench: 3 bang va danh sach index (SHOW INDEX).

1.6 Seed du lieu (T04)

database/seed.sql nap **22 benh nhan**, **24 lich hen** va **1 user admin** — du de phan trang (per_page = 5) co y nghĩa. Ngoai ra co database/seed_data.php (lam them) sinh **100–300 ban ghi** ngau nhien de test EXPLAIN tren bang lon.

```

C:/xampp/mysql/bin/mysql.exe -u root < database/schema.sql
C:/xampp/mysql/bin/mysql.exe -u root < database/seed.sql
# Kiem tra:
mysql -u root clinic_appointment_db -e "SELECT
(SELECT COUNT(*) FROM patients) p,

```

```
(SELECT COUNT(*) FROM appointments) a;"
# -> p=22 a=24
```

1.7 Ket noi PDO — Database class (T05)

Thong tin ket noi nam o config/database.php (tach khoi Controller/View). DSN co charset=utf8mb4; options bao gom ERRMODE_EXCEPTION, FETCH_ASSOC, ATTR_EMULATE_PREPARES=false

Listing 6: config/database.php (rut gon)

```
return [
    'host' => '127.0.0.1', 'port' => '3306',
    'dbname' => 'clinic_appointment_db',
    'user' => 'root', 'pass' => '', 'charset' => 'utf8mb4',
    'options' => [
        PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION,
        PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
        PDO::ATTR_EMULATE_PREPARES => false,
    ],
];
```

Listing 7: app/Core/Database.php — Singleton

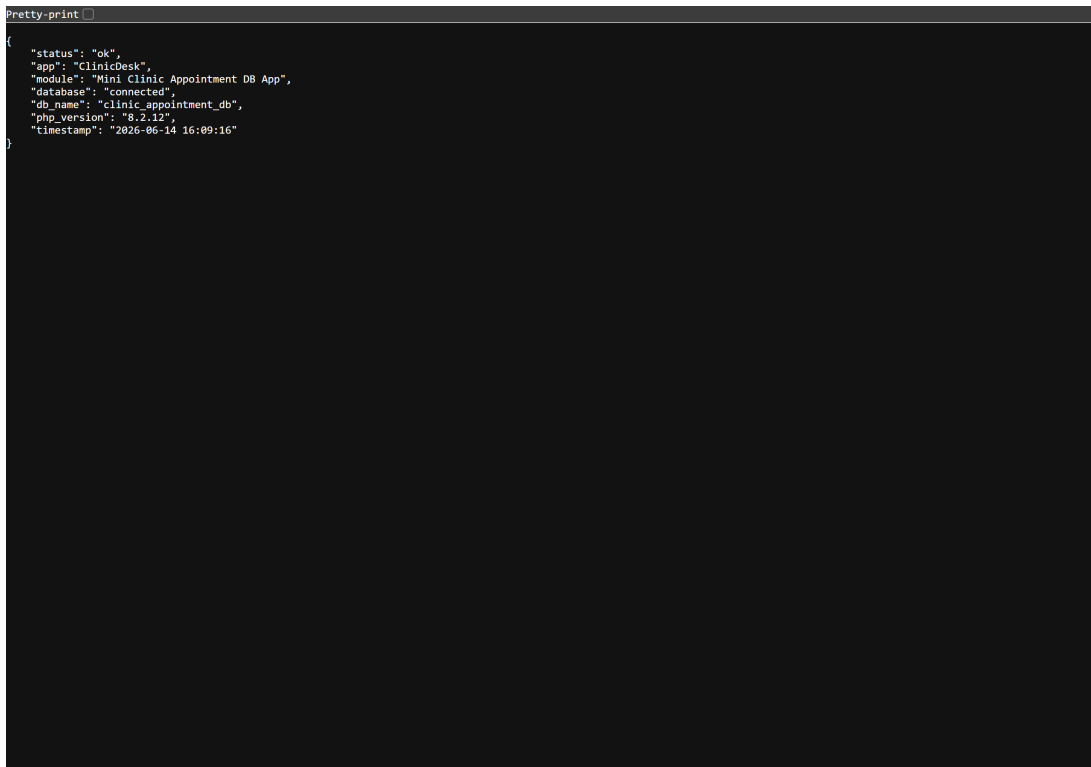
```
class Database {
    private static ?PDO $pdo = null;
    public static function connection(): PDO {
        if (self::$pdo instanceof PDO) return self::$pdo;
        $cfg = self::config();
        $dsn = sprintf('mysql:host=%s;port=%s;dbname=%s;charset=%s',
            $cfg['host'], $cfg['port'], $cfg['dbname'], $cfg['charset']);
        self::$pdo = new PDO($dsn, $cfg['user'], $cfg['pass'], $cfg['options']);
        return self::$pdo;
    }
    public static function isConnected(): bool {
        try { self::connection()->query('SELECT 1'); return true; }
        catch (PDOException $e) {
            Logger::error('Health check DB that bai: '.$e->getMessage());
            return false;
        }
    }
}
```

1.8 Health check (T06)

GET /health tra JSON status=ok va database=connected neu PDO chay duoc SELECT 1, nguoc lai tra 503 voi database=disconnected. Ket qua thuc te:

Listing 8: GET /health — HTTP 200

```
{
  "status": "ok",
  "app": "ClinicDesk",
  "module": "Mini Clinic Appointment DB App",
  "database": "connected",
  "db_name": "clinic_appointment_db",
  "php_version": "8.2.12",
  "timestamp": "2026-06-10 22:53:00"
}
```



Hình 2: Browser GET /health tra JSON status=ok, database=connected.

1.9 Repository + Prepared Statements (T07)

Toan bo SQL nam trong Repository. INSERT/SELECT/UPDATE/DELETE deu dung prepare() + bindValue() + execute(); khong noi chuoi \$_GET/\$_POST vao SQL.

Listing 9: app/Repositories/PatientRepository.php — INSERT

```
public function create(array $data): int {
    $sql = 'INSERT INTO patients (name, email, phone, gender, a
        ddress)
        VALUES (:name, :email, :phone, :gender, :address)';
```

```

$stmt = $this->db()->prepare($sql);
$stmt->bindValue(':name', $data['name'], PDO::PARAM_STR);
$stmt->bindValue(':email', $data['email'], PDO::PARAM_STR);
$stmt->bindValue(':phone', $data['phone'], PDO::PARAM_STR);
$stmt->bindValue(':gender', $data['gender'], PDO::PARAM_STR);
$stmt->bindValue(':address', $data['address'] !== '' ? $data['address'] : null);
$stmt->execute();
return (int)$this->db()->lastInsertId();
}

```

Listing 10: SELECT list co search + pagination (PARAM_INT cho LIMIT/OFFSET)

```

public function paginate(string $q, string $sort, string $direction,
                        int $limit, int $offset): array {
    $sortColumn = $this->resolveSort($sort); // qua whitelist
    $dir = $this->resolveDirection($direction);
    $sql = 'SELECT id, name, email, phone, gender, address,
            created_at FROM patients';
    $params = [];
    if ($q !== '') {
        $sql .= ' WHERE name LIKE :q1 OR email LIKE :q2 OR
                phone LIKE :q3';
        $like = '%' . $q . '%';
        $params = [':q1'=>$like, ':q2'=>$like, ':q3'=>$like];
    }
    $sql .= " ORDER BY {$sortColumn} {$dir}, id {$dir} LIMIT :
            limit OFFSET :offset";
    $stmt = $this->db()->prepare($sql);
    foreach ($params as $k=>$v) $stmt->bindValue($k, $v, PDO::PARAM_STR);
    $stmt->bindValue(':limit', $limit, PDO::PARAM_INT);
    $stmt->bindValue(':offset', $offset, PDO::PARAM_INT);
    $stmt->execute();
    return $stmt->fetchAll();
}

```

[Anh chup man hinh] Code Repository: prepare()/bindValue()/execute() cho CRUD.

1.10 ORDER BY an toan — Whitelist (T08)

Cot sort va huong sort **khong bao gio lay thang tu \$_GET**. Repository chi chap nhan cot trong mot mang whitelist; gia tri ngoai whitelist tu dong roi ve mac dinh.

Listing 11: Whitelist sort trong PatientRepository

```
private const SORTABLE = [
    'id' => 'id', 'name' => 'name', 'email' => 'email',
    'created_at' => 'created_at',
];
private const DEFAULT_SORT = 'created_at';
private const DEFAULT_DIR = 'DESC';

public function resolveSort(?string $sort): string {
    // Tra ten cot THAT; sort khong hop le -> created_at.
    return self::SORTABLE[(string)$sort] ?? self::SORTABLE[self::DEFAULT_SORT];
}
public function resolveDirection(?string $dir): string {
    $dir = strtoupper(trim((string)$dir));
    return in_array($dir, ['ASC', 'DESC'], true) ? $dir : self::DEFAULT_DIR;
}
```

Vi the chuoai tan cong nhu `sort=id;DROP TABLE patients` khong khop key nao trong `SORTABLE` nen bi thay bang `created_at`; `ORDER BY` luon an toan.

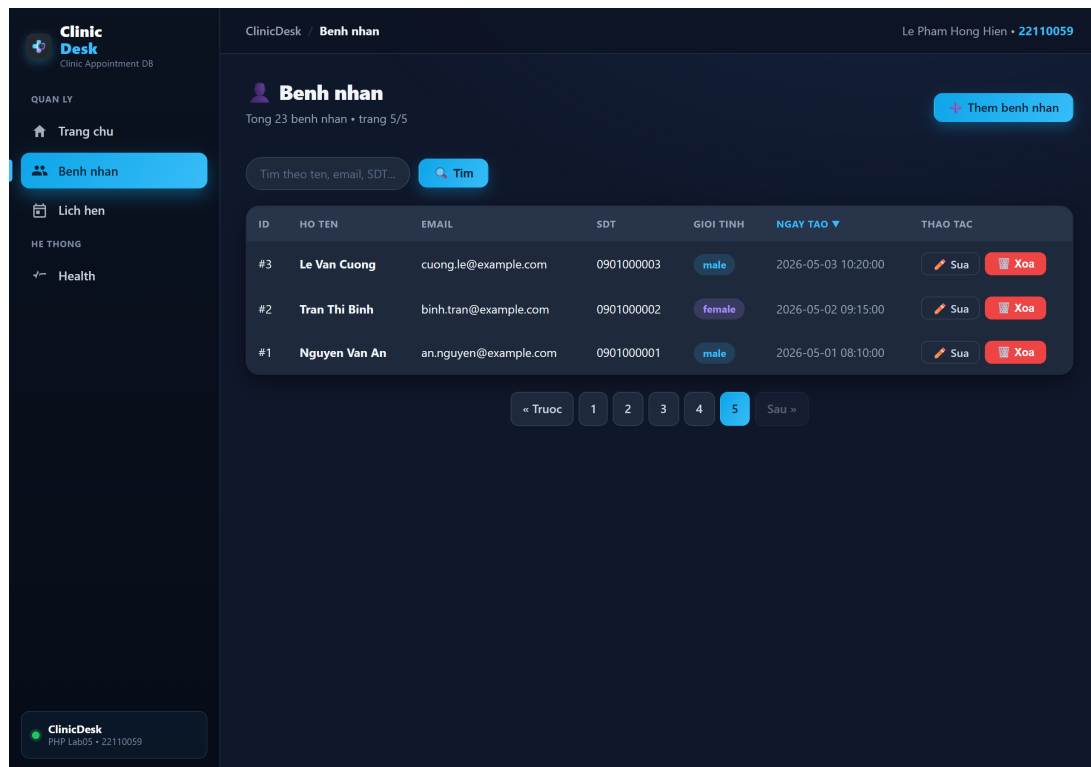
[Anh chup man hinh] Code whitelist SORTABLE + resolveSort/resolveDirection.

1.11 Phan trang an toan — Paginator (T16)

Listing 12: app/Core/Paginator.php

```
public function __construct(int $rawPage, int $perPage, int $total) {
    $this->perPage = max(1, $perPage);
    $this->total = max(0, $total);
    $this->totalPages = (int)max(1, (int)ceil($this->total / $this->perPage));
    $page = $rawPage;
    if ($page < 1) $page = 1; // clamp page am/0
    if ($page > $this->totalPages) $page = $this->totalPages; // clamp qua lon
    $this->page = $page;
    $this->offset = ($this->page - 1) * $this->perPage;
}
```

Ket qua thuc te: `/patients?page=-5` hien “trang 1/5”; `/patients?page=9999` hien “trang 5/5” — deu duoc chuan hoa ve gioi han hop le.



Hình 3: GET /patients?page=9999 duoc clamp ve trang cuoi (trang 5/5).

1.12 Xu ly trung Unique key (T11, T15)

emailExists() / codeExists() la kiem tra “mem” o PHP, nhưng **chot chan that la UNIQUE constraint**. Khi INSERT/UPDATE bi trung, MySQL nem PDOException voi SQLSTATE 23000; Controller bat va tra loi **dung field**, giu lai input cu.

Listing 13: PatientController::store() — bat duplicate

```
try {
    $this->repo->create($data);
} catch (PDOException $e) {
    if ($e->getCode() === '23000') { // vi pham UNIQUE
        $errors['email'] = 'Email nay da ton tai. Vui long dung
            email khac.';
        $this->renderForm('/patients/store', 'create', $data,
            $errors, 409);
        return;
    }
    throw $e; // loi khac -> Router bat -> 500 safe message +
        log
}
Flash::success('Da them benh nhan "'. $data['name']. '" thanh
    cong.');
```

```
Response::redirect('/patients'); // PRG
```

The screenshot shows a web application interface for 'ClinicDesk'. On the left is a sidebar with navigation links: 'Trang chủ', 'Bệnh nhân', 'Lịch hẹn', and 'Health'. The main content area is titled '+ Them bệnh nhân' and contains a form with the following fields:

- Họ tên ***: Input field with 'Nguyen Van Test'.
- Email * (unique)**: Input field with 'an.nguyen@example.com'. Below this field is a red error message: 'Email này đã tồn tại. Vui lòng dùng email khác.'
- Số điện thoại ***: Input field with '0901234567'.
- Giới tính**: A dropdown menu currently showing 'Khác'.
- Địa chỉ**: Input field with '123 Duong Test, Quan 1'.

 At the bottom of the form are two buttons: 'Them moi' (highlighted in blue) and 'Huy'. A 'Quay lại danh sách' button is located in the top right corner of the form area.

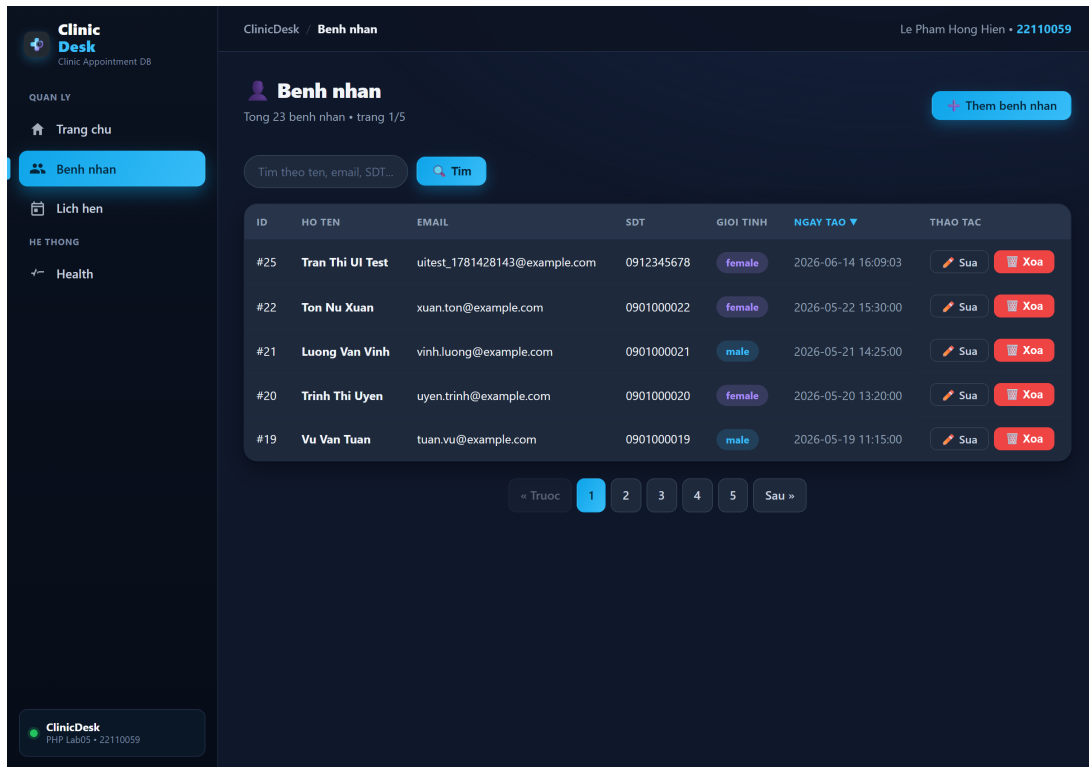
Hình 4: Form tạo bệnh nhân báo lỗi trùng email (HTTP 409), vẫn giữ lại input đã nhập.

1.13 Luong CRUD + PRG Pattern (T10, T12, T13)

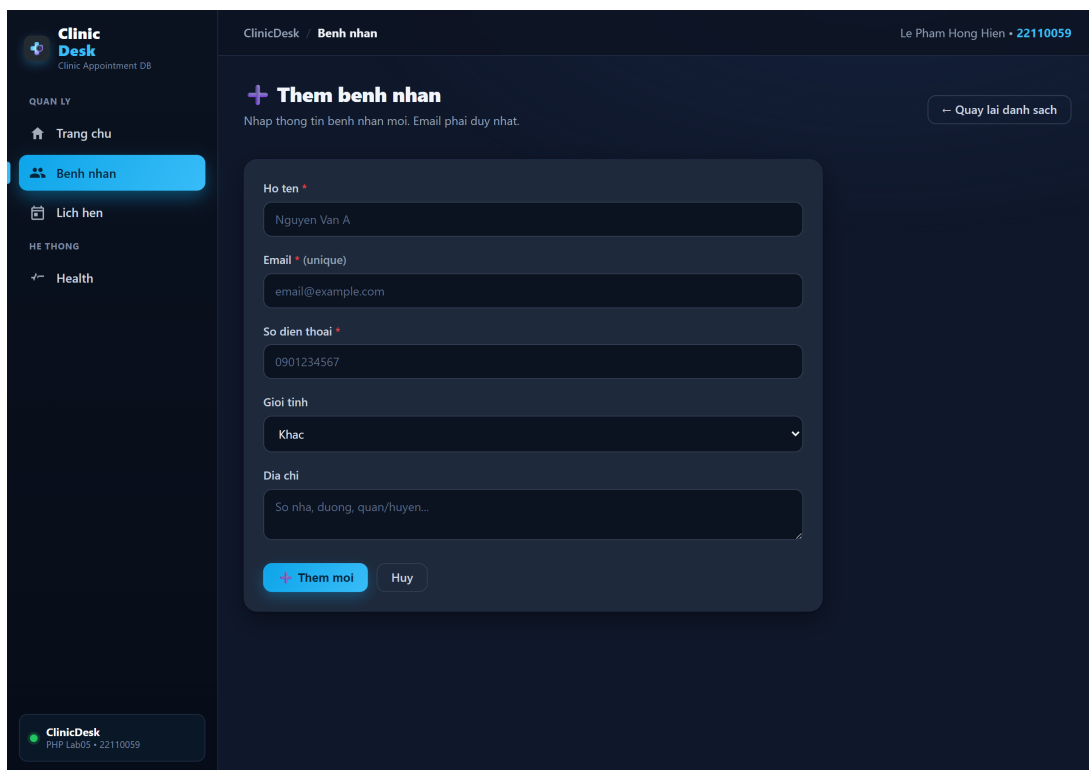
Luong Create/Update đi qua bốn bước: **request** -> **validate** -> **repository** -> **redirect/view**. Validate that bài trả lại form (422) với lỗi từng field; thành công thì **redirect** (PRG, 302) kèm flash. Delete **chỉ qua POST**, có confirm dialog — không dùng GET link.

Listing 14: View: delete bang form POST + confirm

```
<form method="post" action="/patients/delete" class="inline-
  form"
  onsubmit="return confirm('Xoa bệnh nhân #<?=$p['id']
    >?>');">
  <input type="hidden" name="id" value="<?=(int)$p['id'] ?>"
    >
  <button type="submit" class="btn btn-sm btn-danger">Xoa</
    button>
</form>
```



Hình 5: Danh sach benh nhan: bang du lieu, o tim kiem, header sort, nut sua/xoa, phan trang.



Hình 6: Form tao benh nhan moi (GET /patients/create) voi cac truong ho ten, email unique, SDT, gioi tinh, dia chi.

ClinicDesk / Bệnh nhân

Le Pham Hong Hien • 22110059

+ Them bệnh nhân

Nhập thông tin bệnh nhân mới. Email phải duy nhất.

← Quay lại danh sách

Ho ten *

Nguyen Van A

Vui lòng nhập họ tên.

Email * (unique)

email@example.com

Vui lòng nhập email.

So dien thoai *

0901234567

Vui lòng nhập số điện thoại.

Giới tính

Khác

Địa chỉ

Số nhà, đường, quận/huyện...

Them moi Huy

ClinicDesk
PHP Lab05 • 22110059

Hình 7: Submit form rỗng: lỗi field-level từng trường bắt buộc (HTTP 422), không INSERT.

ClinicDesk / Bệnh nhân

Le Pham Hong Hien • 22110059

Sua bệnh nhân #1

Cập nhật thông tin bệnh nhân.

← Quay lại danh sách

Ho ten *

Nguyen Van An

Email * (unique)

an.nguyen@example.com

So dien thoai *

0901000001

Giới tính

Nam

Địa chỉ

12 Le Loi, Quan 1, TP.HCM

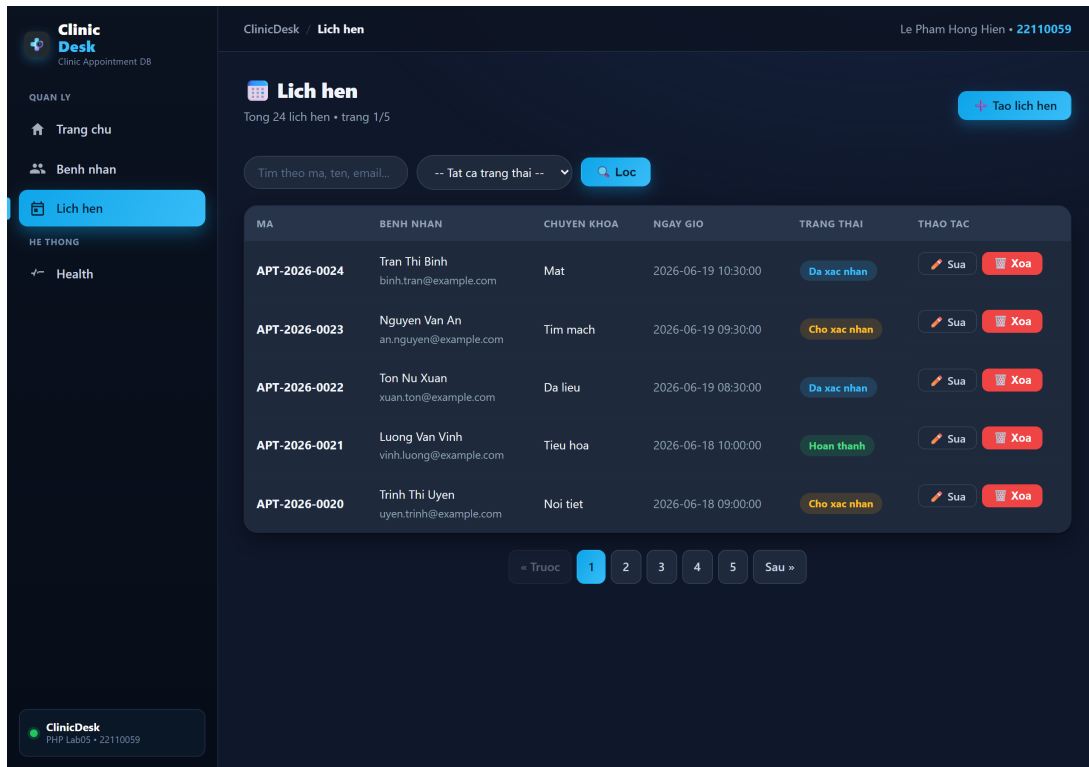
Cap nhat Huy

ClinicDesk
PHP Lab05 • 22110059

Hình 8: Form sửa bệnh nhân (GET /patients/edit?id=1) đã điền sẵn dữ liệu cũ.

1.14 Module Lich hen — search, filter status, sort (T14, T15)

Module /appointments có thêm **filter theo status** (làm thêm) bên cạnh search q. appointment_code UNIQUE chống trùng mã lịch hẹn. Form dùng datetime-local; Controller chuyển sang Y-m-d H:i:s trước khi lưu.



Hình 9: Danh sách lịch hẹn: badge trạng thái, dropdown lọc status, sort theo ngày giờ, phân trang.

1.15 Xử lý lỗi an toàn — 404 / 405 / 500 (T17, T18)

Router bắt mọi Throwable khi gọi handler: ghi log chi tiết rồi trả **500 safe message**. Production (APP_DEBUG=0) **không hiện SQLSTATE**; chỉ khi APP_DEBUG=1 mới hiện chi tiết kỹ thuật.

Listing 15: app/Core/Router.php — runHandler

```
private function runHandler(callable $handler): void {
    try {
        call_user_func($handler);
    } catch (\Throwable $e) {
        Logger::error(sprintf('%s: %s in %s:%d',
            get_class($e), $e->getMessage(), $e->getFile(), $e->getLine()));
        Response::serverError($e->getMessage()); // view tu
            quyet dinh co hien detail
    }
}
```

Thu nghiệm voi DB_NAME=wrong_db_xyz: GET /patients tra **500** voi thong bao “Da co loi xay ra”, khong lo SQLSTATE; nhung trong storage/logs/app.log co dong:

```
[2026-06-10 22:55:50] ERROR: PDOException: SQLSTATE[HY000]
[1049]
Unknown database 'wrong_db_xyz' in .../app/Core/Database.php
:43
```

[Anh chup man hinh] Trang 500 safe message (production) + dong log SQLSTATE trong app.log.

1.16 Bang Routes day du

Method	URL	Controller@Action
GET	/	HomeController@index
GET	/health	HealthController@index (JSON)
GET	/patients	PatientController@index
GET	/patients/create	PatientController@create
POST	/patients/store	PatientController@store
GET	/patients/edit?id=	PatientController@edit
POST	/patients/update	PatientController@update
POST	/patients/delete	PatientController@delete
GET	/appointments	AppointmentController@index
GET	/appointments/create	AppointmentController@create
POST	/appointments/store	AppointmentController@store
GET	/appointments/edit?id=	AppointmentController@edit
POST	/appointments/update	AppointmentController@update
POST	/appointments/delete	AppointmentController@delete
ANY	(khong ton tai)	Router -> 404
(sai method)	(route ton tai)	Router -> 405 + Allow

2 Checklist task T01–T20 va ket qua test

2.1 Checklist task bat buoc T01–T20

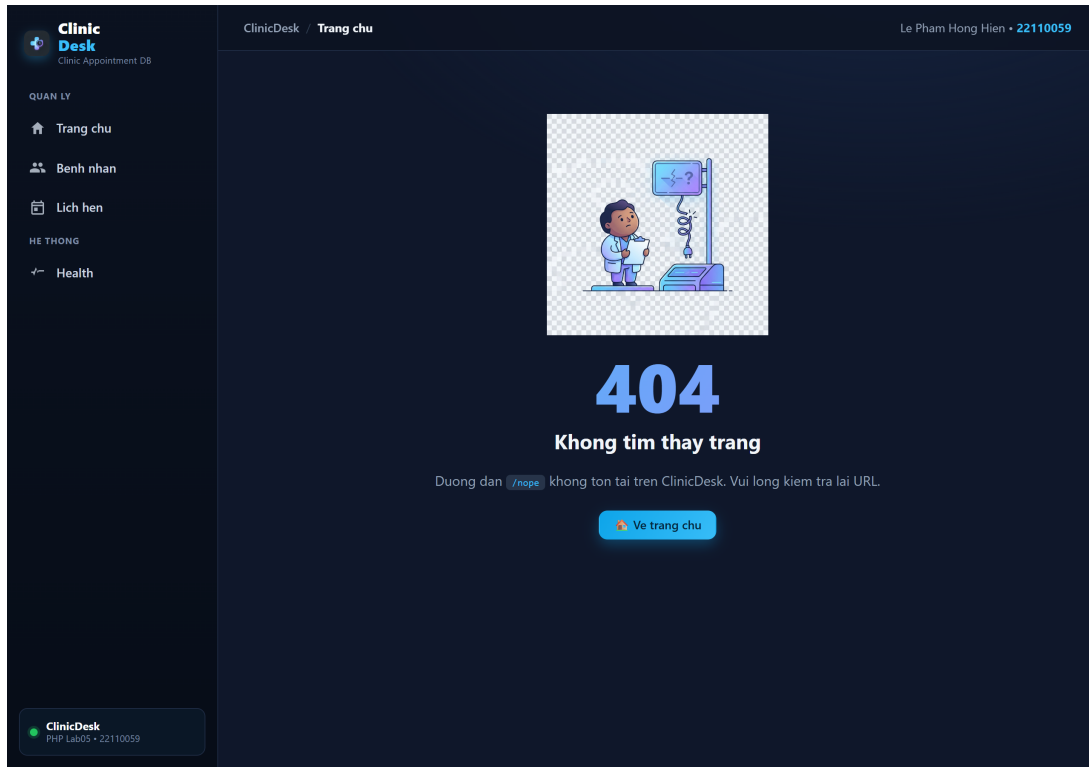
Ma	Task	Trang thai
T01	Kiem tra moi truong (PHP 8.2.12, MariaDB 10.4.32)	✓
T02	Tao cau truc project (public, config, app/Core, Controllers, Repositories, Views, database, storage/logs)	✓
T03	Schema 3 bang co PK/UNIQUE/INDEX	✓
T04	Seed 22 patients + 24 appointments (≥ 15 /module)	✓
T05	PDO config: utf8mb4, ER-MODE_EXCEPTION, FETCH_ASSOC, EMULATE_PREPARES=false	✓
T06	GET /health tra JSON status ok khi DB ket noi	✓
T07	Repository dung prepare()/execute(), khong noi chuoai nguy hiem	✓
T08	ORDER BY qua whitelist sort/direction	✓
T09	List module A: chi SELECT cot can, co search/pagination	✓
T10	Create module A hop le -> redirect + flash success	✓
T11	Duplicate module A -> loi than thien, giu input	✓
T12	Edit/Update module A bang id -> redirect	✓
T13	Delete module A bang POST + confirm (khong GET)	✓
T14	List module B co search/pagination/sort	✓
T15	Create + duplicate module B (appointment_code)	✓
T16	Page am / page qua lon duoc clamp	✓
T17	Sort nguy hiem -> dung sort mac dinh	✓
T18	Safe DB error: khong lo SQLSTATE, co log	✓
T19	EXPLAIN query list/filter/sort, ghi key/index	✓
T20	Git + GitHub (cac moc setup/schema/repository/CRUD/tests)	✓

2.2 Bang ket qua Test (TC01–TC15)

Tat ca ket qua duoi day la **ket qua chay that** bang curl tren `http://127.0.0.1:8105`, ghi lai trong `report/build-notes.md`.

Ma	Cach test	Mong doi	Thuc te	P/F
TC01	GET /health	status=ok, database=connected	HTTP 200, JSON status=ok, database=connected	Pass
TC02	GET /patients	List co search/pagination/ khong loi	HTTP 200, 5 dong/trang, header sort hoat dong	Pass
TC03	POST create pa- tient hop le	Redirect list + flash + co trong DB	HTTP 302 -> /patients, DB co id=23	Pass
TC04	POST create pa- tient thieu re- quired	Loi dung field, khong insert	HTTP 422, loi ten/email/SDT	Pass
TC05	POST create pa- tient trung email	Loi than thien, giu input	HTTP 409, “Email nay da ton tai”, value giu lai	Pass
TC06	GET edit?id hop le	Form hien du lieu cu	HTTP 200, value=email cu; id=99999 -> 404	Pass
TC07	POST update patient hop le	Redirect, du lieu cap nhat	HTTP 302, DB name/address moi	Pass
TC08	POST delete pa- tient	Xoa + redirect	HTTP 302, COUNT id=23 = 0	Pass
TC09	GET /appoint- ments	List co search/filter/sort	HTTP 200, badge status, filter OK	Pass
TC10	POST create ap- pointment trung code	Loi dung field	HTTP 409, “Ma lich hen nay da ton tai”	Pass
TC11	GET URL khong ton tai	404 Not Found	HTTP 404 trang 404	Pass
TC12	POST /health (sai method)	405 Method Not Allowed	HTTP 405, header Allow: GET	Pass
TC13	sort=id;DROP TABLE...	Khong chay SQL nguy hiem, sort mac dinh	HTTP 200, DB con 22 patients (in- tact)	Pass

Ma	Cach test	Mong doi	Thuc te	P/F
TC14	page=-5 va page=9999	Chuan hoa ve gioi han	“trang 1/5” va “trang 5/5”	Pass
TC15	DB loi o produc- tion	Khong hien SQLSTATE, safe message	HTTP 500 safe; log co SQLSTATE; /health 503	Pass



Hình 10: Minh chứng xử lý lỗi: GET /nope trả trang 404 Not Found (route không tồn tại).

2.3 EXPLAIN — Kiểm tra index (T19)

Chạy EXPLAIN cho query lọc + sort chính của module Lich hen (trường hợp hay dùng nhất: lọc theo status rồi sắp xếp mới nhất):

```
EXPLAIN SELECT id, appointment_code, patient_name, appointment_
    date, status
FROM appointments
WHERE status = 'confirmed'
ORDER BY created_at DESC
LIMIT 5 OFFSET 0;
```

table	type	key	key_len	rows	Extra
appointments	ref	idx_appointments_status_created	1	9	Using where

Nhan xet: Cot key = idx_appointments_status_created — query **dung dung composite index** (status, created_at), type=ref (khong full scan). Day la ly do em thiet ke index ghep dung thu tu “loc truoc, sort sau”.

Cac query tra cuu khac cung dung index:

Query	key	type
WHERE appointment_code = 'APT-2026-0003'	uq_appointments_code	const
WHERE email = 'an.nguyen@...' (patients)	uq_patients_email	const
WHERE phone = '0901000001' (patients)	idx_patients_phone	ref

Truong hop key=NULL: Voi query SELECT ... FROM patients ORDER BY created_at DESC LIMIT 5 (khong WHERE), tren bang nho EXPLAIN cho type=ALL, key=NULL, Using filesort. Ly do: optimizer thay quet toan bang roi filesort re hon di vao index + tra ve theo con tro. Khi them dieu kien loc thi index duoc dung ngay:

```
EXPLAIN SELECT id, name FROM patients
WHERE created_at >= '2026-05-01' ORDER BY created_at DESC LIMIT
5;
-- -> type=range key=idx_patients_created_at rows=105 Using
where
```

va khi ep buoc FORCE INDEX(idx_patients_created_at) thi chi quet 5 dong (type=index) thay vi 272 dong + filesort. Tuc la index created_at **co tac dung**; chi la optimizer tu chon ke hoach re nhat tuy kich thuoc du lieu.

*[Anh chup man hinh] Terminal: ket qua EXPLAIN va dong ghi chu
key=idx_appointments_status_created.*

3 Cau 2: Problem Solving

3.1 Cau 2.1 — Database design

Em tách dữ liệu thành ba bảng `users`, `patients`, `appointments` vì mỗi bảng là một **thực thể độc lập** có vòng đời riêng: một bệnh nhân tồn tại không phụ thuộc lịch hẹn, một lịch hẹn có thể được tạo/sửa/hủy mà không sửa hồ sơ bệnh nhân.

Neu gom tất cả vào một bảng lớn (ví dụ một bảng `everything` chứa cả thông tin bệnh nhân lẫn từng lịch hẹn) sẽ gặp:

- **Lap dữ liệu (redundancy):** Một bệnh nhân đặt 5 lịch hẹn thì họ tên, email, SDT bị lặp lại 5 lần. Sửa số điện thoại phải update cả 5 dòng — dễ sai lệch.
- **Bat thường cập nhật/xóa:** Xóa lịch hẹn cuối cùng của một bệnh nhân có thể làm mất luôn thông tin bệnh nhân đó.
- **Kho dữ liệu UNIQUE:** email bệnh nhân đang là unique trên **mọi bệnh nhân** sẽ không thể unique vì bị lặp theo từng lịch hẹn.

Khoa trong schema của em:

- PRIMARY KEY: `users.id`, `patients.id`, `appointments.id`.
- UNIQUE: `patients.email`, `appointments.appointment_code`, `users.username`.
- INDEX: `idx_patients_phone`, `idx_patients_created_at`, `idx_appointments_status_created_at` (`status`, `created_at`), `idx_appointments_date`, `idx_appointments_code`.

3.2 Cau 2.2 — PDO connection

- **charset=utf8mb4:** hồ sơ bệnh nhân có tên tiếng Việt (“Nguyễn Văn An”), địa chỉ có dấu. Thiếu `utf8mb4` (ví dụ dùng `latin1`) thì tên bị lỗi font “?????” và không lưu được emoji.
- **ERRMODE_EXCEPTION:** để lỗi SQL ném `PDOException` thay vì trả `false` âm thầm. Nhờ đó em bắt được `duplicate (SQLSTATE 23000)` và lỗi kết nối để log + hiện `safe message`. Thiếu nó, `INSERT` trùng email sẽ “thất bại im lặng”, user tưởng đã lưu.
- **FETCH_ASSOC:** chỉ lấy mảng keys (`$row['name']`), nhẹ hơn, view dùng `$p['email']` rõ ràng. Mặc định `FETCH_BOTH` trả cả index số lẫn tên biến nên dễ nhầm lẫn.
- **EMULATE_PREPARES=false:** dùng prepared statement thay vì oảng MySQL — chống SQL injection triệt để và dùng kiểu dữ liệu đúng. Nếu để `true` (giả lập), PDO tự ghép chuỗi ở tầng PHP, kém an toàn hơn và `LIMIT :limit` dễ bị ép thành chuỗi gây lỗi cú pháp.

3.3 Cau 2.3 — Prepared statements

INSERT (PatientRepository::create): tất cả giá trị người dùng (`name`, `email`, `phone`...) đều đi qua placeholder `:name`, `:email`, `:phone`... và `bindValue(..., PDO::PARAM_STR)`. Dữ liệu được gửi **tách rời** câu lệnh SQL nên không thể “thoát ra” thành mã SQL. Ví dụ nhập email `x'; DROP TABLE patients;-` thì nó chỉ được lưu nguyên văn như một chuỗi, không chạy.

SELECT (PatientRepository::paginate): từ khóa tìm kiếm `q` được bọc thành `'%'.$q.'` và bind vào `:q1/:q2/:q3`; còn `LIMIT/OFFSET` bind bằng `PARAM_INT`. **Chỉ** có tên cột `ORDER BY ($sortBy)` là được nối trực tiếp vào chuỗi — nhưng giá trị đó đã qua **whitelist**, không phải input thô, nên vẫn an toàn.

3.4 Cau 2.4 — Repository pattern

SQL nen nam trong Repository vi:

- **Tach trach nhien:** Controller lo dieu phoi (validate, redirect), View lo hien thi. Khi mot query can sua (vi du them cot), em chi sua **mot cho** trong Repository.
- **Tai su dung:** `find()`, `countAll()`, `paginate()` duoc goi tu nhieu action ma khong viet lai SQL.
- **De kiem soat an toan:** moi prepared statement va whitelist tap trung mot noi, de review chong injection.

Trong bai cua em, **PatientRepository** xu ly cac query modulebenh nhan, **AppointmentRepository** xu ly module lich hen. View tuyet doi khong co SQL.

3.5 Cau 2.5 — CRUD sach

Luong Create/Update: **request -> validate -> repository -> redirect/view**. Cu the (Createbenh nhan): `store()` gom du lieu `collect()` -> `validate()` -> neu loi tra form (422); neu hop le goi `repo->create()` -> `Flash::success()` -> `Response::redirect('/patients')`.

- **Bo validate:** du lieu rac/thieu (email sai, ten rong) loavailable vao DB; co the nem loi NOT NULL hoac luu sai. UNIQUE van chan trung nhung cac rang buoc dinh dang khac thi mat.
- **Bo PRG:** sau POST ma render thang, khi user bam F5 trinh duyet **gui lai POST** -> tao trung ban ghi (hoac bao loi duplicate). PRG (redirect) bien trang sau thanh GET nen F5 chi tai lai danh sach, an toan.

3.6 Cau 2.6 — Unique constraint va duplicate key

Chi kiem tra trung bang PHP (`emailExists()`) la chua du vi **race condition**: hai request gan nhu dong thoi cung kiem tra “email chua ton tai” (ca hai deu thay chua co), roi ca hai cung INSERT. Ket qua co **hai dong trung email**.

Voi UNIQUE KEY `uq_patients_email`, du hai request vuot qua kiem tra PHP, MySQL van chi cho **mot** INSERT thanh cong; cai con lai nem `SQLSTATE 23000`. Em bat exception nay va hien loi than thien. Tuong tu `appointment_code` chong tao trung ma lich hen khi hai le tan nhap cung luc.

3.7 Cau 2.7 — PRG Pattern

Sau POST thanh cong, project cua em **redirect ve trang list** (`/patients` hoac `/appointments`) bang `Response::redirect()` (302) kem flash message qua session.

Neu render truc tiep sau POST: URL van la `/patients/store`; khi user bam **F5**, trinh duyet hoi “gui lai bieu mau?” va gui lai POST -> **tao trung** ban ghi (vi du them 2benh nhan giong het, hoac 2 lan duplicate error). PRG loai bo hoan toan van de nay.

3.8 Cau 2.8 — Search, pagination va sort an toan

URL list cua em co cac tham so: `q` (tim kiem), `page` (trang), `sort` (cot), `direction` (asc/desc), rieng appointments co them `status` (loc trang thai).

- **page am / page = 0:** Paginator clamp về 1.
- **page qua lon:** clamp về totalPages (ví dụ page=9999 -> trang 5/5).
- **sort không hợp lệ:** resolveSort() tra về cột mặc định created_at nếu không nằm trong whitelist.
- **direction không hợp lệ:** resolveDirection() chỉ cho ASC/DESC, khác đi -> DESC.
- **status không hợp lệ:** Controller bỏ qua filter nếu giá trị không thuộc ENUM.

3.9 Cau 2.9 — Index va EXPLAIN

Query loc + sort của em:

```
SELECT id, appointment_code, patient_name, appointment_date,
       status
FROM appointments WHERE status='confirmed'
ORDER BY created_at DESC LIMIT 5;
```

EXPLAIN cho key = idx_appointments_status_created, type=ref, rows=9 — **compound index** composite (status, created_at).

Nếu key=NULL trên bảng lớn, em sẽ: (1) thêm index phù hợp với mệnh đề WHERE/ORDER BY (ví dụ index (status, created_at) cho dùng mau loc-roi-sort); (2) tránh LIKE '%q%' đầu dòng (không dùng được index) bảng full-text hoặc tìm theo prefix; (3) giới hạn cột SELECT để có thể **covering index**; (4) thêm điều kiện lọc (ví dụ khoảng thời gian) để chuyển từ full scan sang range scan — như thực nghiệm patients (created_at >= ? -> type=range).

3.10 Cau 2.10 — Safe error message

Production không nên hiển thị `$e->getMessage()/SQLSTATE` vì: (1) **lo thông tin nhạy cảm** — tên DB, tên bảng, cấu trúc query — giúp kẻ tấn công dò schema; (2) trải nghiệm người dùng kém, rồi rắc kỹ thuật.

Trong bài của em, lỗi DB đi qua `Router::runHandler()` -> `Logger::error()` ghi **day du** (class, message, file, dòng) vào `storage/logs/app.log`; con giao diện hiển thị **safe message** “Đã có lỗi xảy ra. Lỗi đã được ghi log”. Chỉ khi `APP_DEBUG=1` (lúc phát triển) trang 500 mới hiển thị chi tiết [DEBUG].

3.11 Cau 2.11 — Delete bang POST

Delete không nên dùng GET link vì GET phải **idempotent / an toàn** (chỉ đọc). Rủi ro nếu dùng `<a href="/patients/delete?id=5">`:

- **Crawler / bot** (Google, antivirus) tu động đi theo mọi link GET -> **xóa sạch dữ liệu** mà không ai bấm.
- **Trình duyệt prefetch / preview link** (chat, email) có thể gọi trước URL -> xóa nhầm.
- **Click nhầm / lịch sử trình duyệt** để vô tình xóa.

Vì thế em xóa bằng `<form method="post" action="/patients/delete">` kèm `confirm()`; truy cập GET `/patients/delete` trả **405 Method Not Allowed** (đã kiểm chứng).

3.12 Cau 2.12 — Huong phat trien tiep theo

Neu nang cap ClinicDesk thanh he thong that, em uu tien theo thu tu:

1. **Authentication / session:** du lieu benh nhan la **thong tin y te nhay cam** — bat buoc dang nhap truoc khi xem/sua. Bang `users` (co `password_hash`) da chuan bi san.
2. **CSRF token:** form create/update/delete can token chong gia mao yeu cau, dac biet khi da co session dang nhap.
3. **Role permission:** le tan vs bac si vs admin co quyen khac nhau (vi du chi admin duoc xoa benh nhan).
4. **Soft delete (`deleted_at`):** ho so y te khong nen xoa cung; an di de con truy vet lich su kham.
5. **Transaction:** khi mo rong sang lich hen co nhieu dich vu/hoa don con, can transaction de tao “don + chi tiet” nhat quan.
6. **Service layer + logging + API:** tach Service cho Controller mong hon, log truy cap, va API JSON cho app dat lich phia benh nhan.

Em uu tien auth + CSRF + role **truoc** vi tinh rieng tu/bao mat du lieu y te la quan trong nhat voi bai toan phong kham.

4 Ket luan

Bai thuc hanh Lab05 giup em xay dung hoan chinh **ClinicDesk — Mini Clinic Appointment DB App** va hieu sau:

- Thiet ke **database chuan hoa** voi PRIMARY KEY, UNIQUE va INDEX dung muc dich (composite (**status**, **created_at**) cho mau loc-roi-sort).
- Ket noi **PDO** an toan (utf8mb4, ERRMODE_EXCEPTION, FETCH_ASSOC, EMULATE_PREPARES=false) qua lop Database Singleton.
- **Repository** gom toan bo SQL, dung **prepared statements**; ORDER BY qua **whitelist** chong SQL injection.
- **CRUD sach** cho ca hai module voi validate, **PRG**, flash, giu input khi loi.
- **Pagination** clamp page am/qua lon; **UNIQUE** + bat SQLSTATE 23000 cho loi duplicate than thien.
- **Xu ly loi an toan**: log SQLSTATE ra file, hien safe message; phan biet 404/405/500.
- **EXPLAIN** xac nhan query loc/sort dung dung index.

Diem noi bat (lam them so voi yeu cau toi thieu):

- database/seed_data.php sinh **100–300 ban ghi** ngau nhien de test pagination va EXPLAIN tren bang lon.
- **Filter theo status** ben canh search q cho module lich hen.
- **Sort direction toggle** asc/desc bang cach bam header cot (ca hai module).
- **Logging** chuyen biet vao storage/logs/app.log khi DB loi.
- **APP_DEBUG toggle**: production an SQLSTATE, debug hien chi tiet — da kiem chung ca hai.
- Bang users voi password_hash bcrypt san sang cho auth/role.

5 Bang kiem tra yeu cau (coverage)

Yeu cau	Trang thai
Project chay duoc bang php -S 127.0.0.1:8105 -t public	✓
Front Controller tai public/index.php + Router + Response	✓
Tach config: config/app.php, config/database.php (ngoai Controller/View)	✓
3 bang users + patients + appointments, PK/UNIQUE/INDEX	✓
Seed >= 15 ban ghi/module (22 patients, 24 appointments)	✓
PDO: utf8mb4, ERRMODE_EXCEPTION, FETCH_ASSOC, EMULATE_PREPARES=false	✓
Database class quan ly ket noi (Singleton)	✓
Repository cho 2 module, toan bo SQL trong Repository	✓
Prepared statements cho INSERT/SELECT/UPDATE/DELETE	✓
CRUD day du 2 module: List/Create/Edit/Update/Delete	✓
Search + pagination + sort whitelist (cot + direction)	✓
Page <= 0 va page > max duoc clamp	✓
Sort nguy hiem -> fall back mac dinh an toan	✓

Yeu cau	Trang thai
UNIQUE chan trung email + appointment_code, loi field-level giu input	✓
PRG sau create/update/delete (redirect 302) + flash	✓
Delete bang POST + confirm (khong GET link)	✓
GET / dashboard, GET /health JSON connected	✓
Error view 404 / 405 (Allow header) / 500	✓
Production khong lo SQLSTATE; log vao storage/logs	✓
EXPLAIN co dung index (idx_appointments_status_created)	✓
Khong co SQL trong View; khong ghep \$_GET/\$_POST vao SQL	✓
Git + GitHub (https://github.com/lphhien112-gif/PHP-)	✓